

Apache Fineract — Legacy-to-AWS Migration Architecture Package

Repository: COG-GTM/fineract-Core-Banking

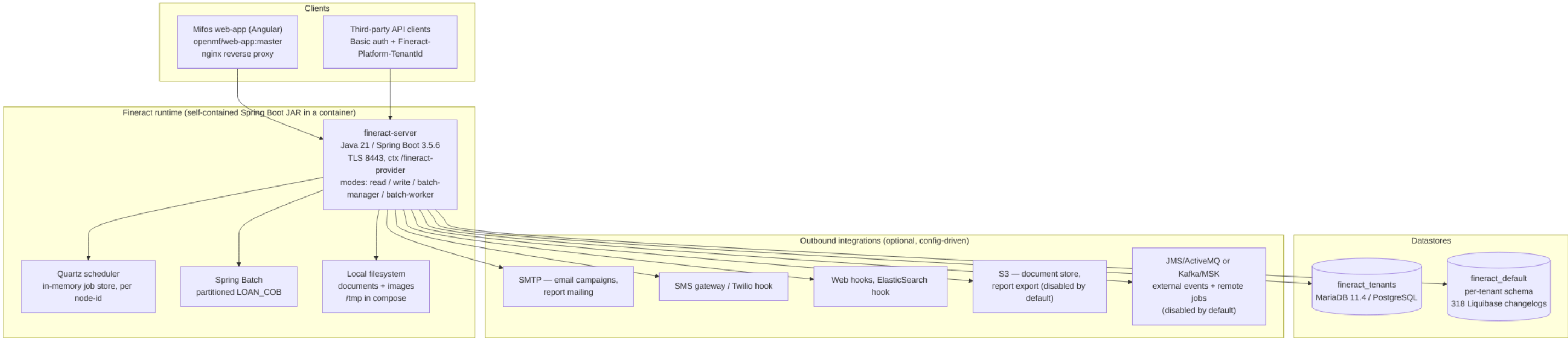
Current state derived from the repository, an AWS target state assessed against the platform migration guardrails, the open questions that must be closed before design sign-off, and an ordered migration plan ending at production cutover.

The approved AWS service list and the platform guardrails were not supplied for this package. Both are **assumed defaults, explicitly labelled as assumptions** in the target-state document, and confirming them is open question OQ-P1 / OQ-P2.

1. [Current State](#)
2. [Target State \(guardrails and guardrail compliance\)](#)
3. [Open Questions](#)
4. [Migration Plan](#)

Current State — Apache Fineract (COG-GTM/fineract-Core-Banking)

Derived from the `develop` branch at commit `8c187f9d1`. Every claim below cites the file and line it was read from. Anything not read directly from this repository is prefixed **Inference:**.



1. Runtime and framework inventory

Fact	Value	Evidence
Language / toolchain	Java 21	<code>build.gradle:395</code> (<code>JavaLanguageVersion.of(21)</code>), <code>README.md:34</code>
Framework	Spring Boot 3.5.6	<code>build.gradle:113</code>
Build	Gradle multi-module, 32 <code>include</code> entries	<code>settings.gradle</code> (32 lines beginning <code>include</code>)
Packaging (primary)	Self-contained Spring Boot JAR, containerised by Jib	<code>fineract-provider/build.gradle:264-296</code> , <code>README.md:36</code>
Packaging (secondary)	Deployable WAR <code>fineract-provider.war</code> for external Tomcat ≥ 10	<code>fineract-war/build.gradle:21,27</code> , <code>README.md:36</code>
Base image	<code>azul/zulu-openjdk-alpine:21</code>	<code>fineract-provider/build.gradle:266</code>
Container user	<code>nobody:nogroup</code>	<code>fineract-provider/build.gradle:295</code>
Exposed ports	8080/tcp, 8443/tcp; server port 8443, context <code>/fineract-provider</code>	<code>fineract-provider/build.gradle:293</code> , <code>application.properties:382-383</code>
ORM	EclipseLink JPA with compile-time static weaving	<code>STATIC_WEAVING.md</code> , <code>static-weaving.gradle</code>

EOL status. Java 21 is an LTS release and Spring Boot 3.5.x is a current supported line, so this is not a runtime-EOL migration. **Inference:** support-window dates come from vendor lifecycle pages, not from this repository.

2. Datastores

Fact	Value	Evidence
Supported engines	MariaDB $\geq 11.5.2$ or PostgreSQL ≥ 18.0	<code>README.md:33</code>
Default engine in config	MariaDB via <code>org.mariadb.jdbc.Driver</code>	<code>application.properties:405-406</code>
Multi-tenancy	Database-per-tenant: a <code>fineract_tenants</code> registry DB plus one DB per tenant, selected by the <code>Fineract-Platform-TenantId</code> header	<code>application.properties:44-53,406</code> , <code>kubernetes/fineractmysql-configmap.yml:29-30</code>

Fact	Value	Evidence
Connection pool	HikariCP, max pool 10, TRANSACTION_REPEATABLE_READ	application.properties:409-415
Read replica support	Optional read-only host/port/credentials per tenant	application.properties:56-62
Schema management	Liquibase, runs on application start (spring.liquibase.enabled default true), master changelog db/changelog/db.changelog-master.xml	application.properties:433-434
Migration volume	318 Liquibase changelog XML files across modules	find . -path "*db/changelog*" -name "*.xml" \ wc -l = 318
Tenant upgrade concurrency	Deliberately single-threaded because of an open Liquibase thread-safety issue	application.properties:157-160
Both drivers shipped in the image	mariadb-java-client and postgresql added to the Jib container classpath	fineract-provider/build.gradle:300-303

3. Data access style (the negatives matter)

Pattern	Count	Evidence
Files using JdbcTemplate (non-test)	204	grep -rl JdbcTemplate --include=*.java excluding /test/
createNativeQuery call sites (non-test)	1	grep -rn createNativeQuery --include=*.java
@Query(nativeQuery = true)	1	grep -rn "nativeQuery *= *true" --include=*.java
Stored procedures / CallableStatement	0	grep -rni "CREATE PROCEDURE\ StoredProcedure\ callableStatement" over *.java, *.sql, *.xml
@Scheduled annotations (non-test)	0	grep -rn "@Scheduled" --include=*.java — all scheduling goes through Quartz/Spring Batch
WebClient usages	0	grep -rn WebClient --include=*.java
RestTemplate references	15	grep -rn RestTemplate --include=*.java
Files using OkHttp	22	grep -rln okhttp3 --include=*.java

The zero stored-procedure count is the load-bearing fact for a MariaDB → PostgreSQL move: schema and data conversion is in scope, but there is no procedural database code to port. The 204 files that use JdbcTemplate are the SQL-dialect surface that has to be regression-tested — and the project already runs its full test suite against MariaDB, MySQL and PostgreSQL (.github/workflows/build-mariadb.yml, build-mysql.yml, build-postgresql.yml).

4. Scheduling and batch

Fact	Value	Evidence
Scheduler	Quartz, one scheduler created programmatically per tenant/group	JobRegisterServiceImpl.java:319-331
Job store	Default (in-memory RAMJobStore) — only PROP_THREAD_COUNT is set and no org.quartz.jobStore property exists anywhere in the repo	JobRegisterServiceImpl.java:325-327; grep -rn jobStore over *.java/*.properties returns 0 non-test matches
Job-to-node binding	A job runs only on the node whose fineract.node-id matches the job's stored node_id (or 0 = any)	JobRegisterServiceImpl.java:172,206-212,223-230, application.properties:22
Close-of-business	Spring Batch partitioned job LOAN_COB, chunk 100 / partition 100, 5 threads, retry 5	application.properties:88-95, fineract.job.loan-cob-enabled at :81
Manager / worker split	Four independent mode switches: read, write, batch-manager, batch-worker	application.properties:67-70; compose profiles at config/docker/env/fineract-manager.env:20-26 and fineract-worker.env:20-24
Remote job dispatch	Spring events (default on), JMS/ActiveMQ (off), or Kafka (off)	application.properties:97-122
Spring Batch schema init	NEVER; auto-run of batch jobs disabled	application.properties:467-469

5. Messaging and eventing

Fact	Value	Evidence
External events	Avro-encoded business events, disabled by default	<code>application.properties:124-128</code>
Producers available	JMS (<code>tcp://127.0.0.1:61616</code> default) or Kafka (<code>localhost:9092</code> default)	<code>application.properties:129-152</code>
Kafka-on-AWS profile exists	Compose profile targeting Amazon MSK with <code>SASL_SSL</code> + <code>AWS_MSK_IAM</code>	<code>docker-compose-postgresql-kafka-msk.yml:27-59</code> , <code>config/docker/env/kafka-client-msk.env:23-33</code>
MSK bootstrap endpoints committed	Three <code>b-N-public.democluster1....eu-central-1.amazonaws.com:9198</code> public broker endpoints are hard-coded	<code>config/docker/env/kafka-client-msk.env:23,31</code>

6. Outbound integrations

Integration	How	Evidence
SMTP e-mail (campaigns, report mailing)	Jakarta Mail / <code>JavaMailSender</code> , 7 files	<code>GmailBackedPlatformEmailService.java</code> , <code>EmailCampaignWritePlatformCommandHandlerImpl.java</code> , <code>ReportMailingJobEmailServiceImpl.java</code>
SMS	External message-gateway host/port/endpoint plus tenant app key	<code>ExternalServicesPropertiesReadPlatformServiceImpl.java:136-142</code>
Hooks (outbound)	Web hook, Twilio, ElasticSearch, message gateway	<code>fineract-provider/src/main/java/org/apache/fineract/infrastructure/hooks/processor/</code>
Object storage	S3 for document content and for report export, both disabled by default	<code>application.properties:188-194,202-203</code>
Metrics	Prometheus scrape endpoint and CloudWatch export, both off by default; actuator exposure limited to <code>health,info,prometheus</code>	<code>application.properties:347,358,362-367</code>
Tracing	OTLP export off by default, <code>OTEL_SERVICE_NAME</code> set per compose service	<code>application.properties:349,354-356</code> , <code>config/docker/env/fineract-common.env:59</code>
AWS SDK config	Region, endpoint override, static keys, instance profile or shared-profile file	<code>application.properties:372-378</code>

Credentials for S3, SMTP and the SMS gateway are **read from a database table at runtime**, not from configuration files (`ExternalServicesPropertiesReadPlatformServiceImpl.java:54-94,154`).

7. Stateful local disk

Fact	Value	Evidence
Document/image store default	Local filesystem at <code>\${user.home}/.fineract</code>	<code>application.properties:186-187</code>
Compose override	<code>/tmp</code> inside the container	<code>config/docker/env/fineract-common.env:57</code>
Command dead-letter queue (opt-in)	File path <code>/tmp/fineract-command-audit</code>	<code>application.properties:617-618</code>
Kubernetes	The <code>fineract-server</code> pod mounts no volume for content — only the MariaDB pod has a PVC	<code>kubernetes/fineract-server-deployment.yml</code> (no <code>volumeMounts</code>), <code>kubernetes/fineractmysql-deployment.yml:119-130</code>

Uploaded client documents therefore live on ephemeral container storage unless S3 is enabled.

8. Hosting model as committed

Docker Compose (development)

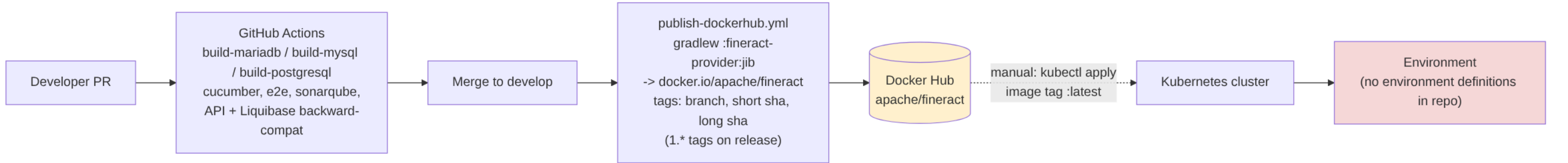
Fact	Evidence
Default stack = MariaDB 11.4 + one Fineract container	<code>docker-compose.yml:19-39</code> , <code>config/docker/compose/mariadb.yml:20-21</code>

Fact	Evidence
Ports published: 8443 (API) and 5000 (JDWP debugger)	docker-compose.yml:31-32, config/docker/env/fineract-common.env:60 (-agentlib:jdwp=... address=*:5000)
Compose runs with <code>SPRING_PROFILES_ACTIVE=test,diagnostics</code>	config/docker/env/fineract-common.env:58
Database password committed in the env file	config/docker/env/fineract-common.env:31 and :51 (value not reproduced here)
Nine compose variants: MariaDB, MySQL, PostgreSQL, PostgreSQL+ActiveMQ, PostgreSQL+Kafka, PostgreSQL+MSK, custom, development, web-app	repository root listing
Manager/worker topology exists in the Kafka variants: 1 manager + 2 worker replicas	docker-compose-postgresql-kafka.yml:33-63

Kubernetes (the only committed deployment target)

Fact	Evidence
Three manifests applied by a shell script; no Helm chart, no Kustomize, no IaC of any kind in the repo	kubernetes/kubectl-startup.sh:25-45
App exposed by a <code>Service</code> of type: <code>LoadBalancer</code> directly on 8443 — no Ingress, no WAF	kubernetes/fineract-server-deployment.yml:26-34
Deployment strategy <code>Recreate</code> — every release is a full outage	kubernetes/fineract-server-deployment.yml:49-50
Image <code>apache/fineract:latest</code> (mutable tag, public Docker Hub)	kubernetes/fineract-server-deployment.yml:63
Single replica (no <code>replicas:</code> field $\Rightarrow$ 1)	kubernetes/fineract-server-deployment.yml:44-50
Probes: liveness/readiness on <code>/fineract-provider/actuator/health/{liveness,readiness}</code> over HTTPS	kubernetes/fineract-server-deployment.yml:71-86
Resources: 200m/1Gi request, 1000m/2Gi limit, <code>-Xmx1G</code>	kubernetes/fineract-server-deployment.yml:64-70,122-123
Database runs in-cluster as <code>mariadb:11.4</code> with a <code>hostPath</code> <code>PersistentVolume</code> at <code>/mnt/data</code>	kubernetes/fineractmysql-deployment.yml:20-47,89
DB secret is generated ad hoc by a shell script (<code>root</code> + 16 random chars) and never rotated	kubernetes/kubectl-startup.sh:24
Init SQL grants <code>ALL ON *.* to root@'%'</code>	kubernetes/fineractmysql-configmap.yml:32-33
Web UI <code>openmf/web-app:master</code> (mutable tag) behind nginx with <code>proxy_ssl_verify off</code>	kubernetes/fineract-mifoscommunity-deployment.yml:48,102, service at :68,73

9. Release flow as committed



Fact	Evidence
19 GitHub Actions workflows: build per database engine, cucumber, e2e, docs, Sonar, API and Liquibase backward-compatibility, commit checks, Dockerhub publish	.github/workflows/
Image published on push to <code>develop</code> and on <code>1.*</code> tags, using Jib and Docker Hub credentials	.github/workflows/publish-dockerhub.yml:2-7,43-48
Multi-arch build <code>linux/amd64,linux/arm64</code>	.github/workflows/publish-dockerhub.yml:46

Fact	Evidence
There is no deployment pipeline. No workflow references <code>kubectl</code> , <code>helm</code> , <code>argo</code> , or any deploy step	<code>grep -rn "deploy\ kubectl\ helm\ argo\ harness" .github/workflows</code> returns only test-artifact paths and job names
Promotion to an environment is therefore manual <code>kubectl apply</code>	<code>kubernetes/kubectl-startup.sh:25-45</code>

10. Authentication, session and secrets model

Fact	Value	Evidence
Default auth	HTTP Basic, stateless, tenant selected by header	<code>application.properties:24</code> , <code>README.md:73-78</code>
OAuth2	Present but disabled by default; example client registration points at <code>http://localhost:3000/callback</code>	<code>application.properties:25,37-42</code>
Two-factor	Disabled by default	<code>application.properties:26</code>
HSTS	Disabled by default	<code>application.properties:27</code>
CORS	<code>allowed-origin-patterns=*</code> with <code>allow-credentials=true</code> ; actuator CORS <code>allowed-origins=*</code>	<code>application.properties:31,35,341</code>
TLS	Enabled, but with a bundled self-signed keystore <code>classpath:keystore.jks</code> and a default keystore password	<code>application.properties:386-391</code>
Outbound TLS verification	<code>fineract.insecure-http-client</code> defaults to true	<code>application.properties:221</code> ; compose sets it explicitly at <code>config/docker/env/fineract-common.env:56</code>
Runtime secrets	Env vars in compose; Kubernetes <code>Secret</code> created by shell script; external-service credentials in the tenant database	<code>config/docker/env/*.env</code> , <code>kubernetes/kubectl-startup.sh:24</code> , <code>ExternalServicesPropertiesReadPlatformServiceImpl.java:54-94</code>
Committed AWS credentials file	<code>config/docker/aws/etc/credentials</code> contains localstack placeholder values (10-character key and secret), not live credentials; it is bind-mounted into the container	<code>config/docker/compose/fineract.yml:25</code> , <code>config/docker/env/aws.env:26-29</code>

11. Contradictions and defects found between artefacts

These are recorded as current-state facts. Fixing them is out of scope for this docs-only package; the migration plan references them as cutover blockers.

#	Finding	Evidence
C1	Three different image coordinates for the same artefact: CI publishes <code>apache/fineract</code> with immutable sha tags, Kubernetes pulls <code>apache/fineract:latest</code> , Compose expects a locally built <code>fineract:latest</code> . Nothing guarantees the cluster runs the tested build.	<code>.github/workflows/publish-dockerhub.yml:47</code> , <code>kubernetes/fineract-server-deployment.yml:63</code> , <code>config/docker/compose/fineract.yml:21</code>
C2	<code>kafka-client-msk.env:33</code> sets <code>FINERACT_EXTERNAL_EVENTS_KAFKA_PRODUCER_EXTRA_PROPERTIES</code> with a colon rather than <code>=</code> . In an <code>env_file</code> this line is not a valid assignment, so the MSK IAM producer properties are silently not applied while the neighbouring admin/consumer lines (<code>:32</code> , and <code>:24-26</code>) are.	<code>config/docker/env/kafka-client-msk.env:24-26,32-33</code>
C3	The Kubernetes MariaDB <code>PersistentVolume</code> uses <code>hostPath: /mnt/data</code> with <code>accessModes: ReadWriteMany</code> and <code>storageClassName: manual</code> — a single-node/minikube construct. It cannot be scheduled safely on a multi-node managed cluster.	<code>kubernetes/fineractmysql-deployment.yml:26-47</code>
C4	The workload's only ingress path is a <code>type: LoadBalancer</code> Service publishing 8443 with the application's bundled self-signed certificate; the UI proxy then disables certificate verification (<code>proxy_ssl_verify off</code>).	<code>kubernetes/fineract-server-deployment.yml:26-34</code> , <code>kubernetes/fineract-mifocommunity-deployment.yml:48</code>
C5	Compose publishes a JDWP debug agent on port 5000 with <code>address=*:5000</code> , and runs the <code>test,diagnostics</code> Spring profiles. Fine for a laptop; a hard blocker if this compose file is ever the basis of a deployed environment.	<code>docker-compose.yml:32</code> , <code>config/docker/env/fineract-common.env:58,60</code>
C6	Real-looking MSK public broker endpoints for a named cluster in <code>eu-central-1</code> are committed. Public MSK access contradicts private-networking baselines.	<code>config/docker/env/kafka-client-msk.env:23,31</code>
C7	The Quartz scheduler is created with only a thread count, i.e. the default in-memory job store. With <code>Recreate</code> deployments and node-bound jobs, an in-flight COB run is lost on restart and there is no cluster-wide job lock.	<code>JobRegisterServiceImpl.java:319-331</code> , <code>kubernetes/fineract-server-deployment.yml:49-50</code>
C8	The README documents a 16 GB / 8-core minimum while the Kubernetes manifest caps the pod at 1 vCPU / 2 GiB with <code>-Xmx1G</code> .	<code>README.md:32</code> , <code>kubernetes/fineract-server-deployment.yml:64-70,122-123</code>
C9	The <code>fineractmysql</code> Service is headless (<code>clusterIP: None</code>) but its selector <code>tier: fineractmysql</code> sits under the same <code>app: fineract-server</code> label as the API deployment, and the API's init container waits on the hostname <code>fineractmysql</code> — naming that says MySQL for what is actually MariaDB 11.4.	<code>kubernetes/fineractmysql-deployment.yml:51-65,89</code> , <code>kubernetes/fineract-server-deployment.yml:57-60</code>

#	Finding	Evidence
C10	Documents uploaded through the API are written to container-local storage (/tmp in compose, \${user.home}/.fineract by default) and the app pod has no volume; S3 content storage is off by default. Any restart loses uploaded documents.	application.properties:186-188, config/docker/env/fineract-common.env:57, kubernetes/fineract-server-deployment.yml

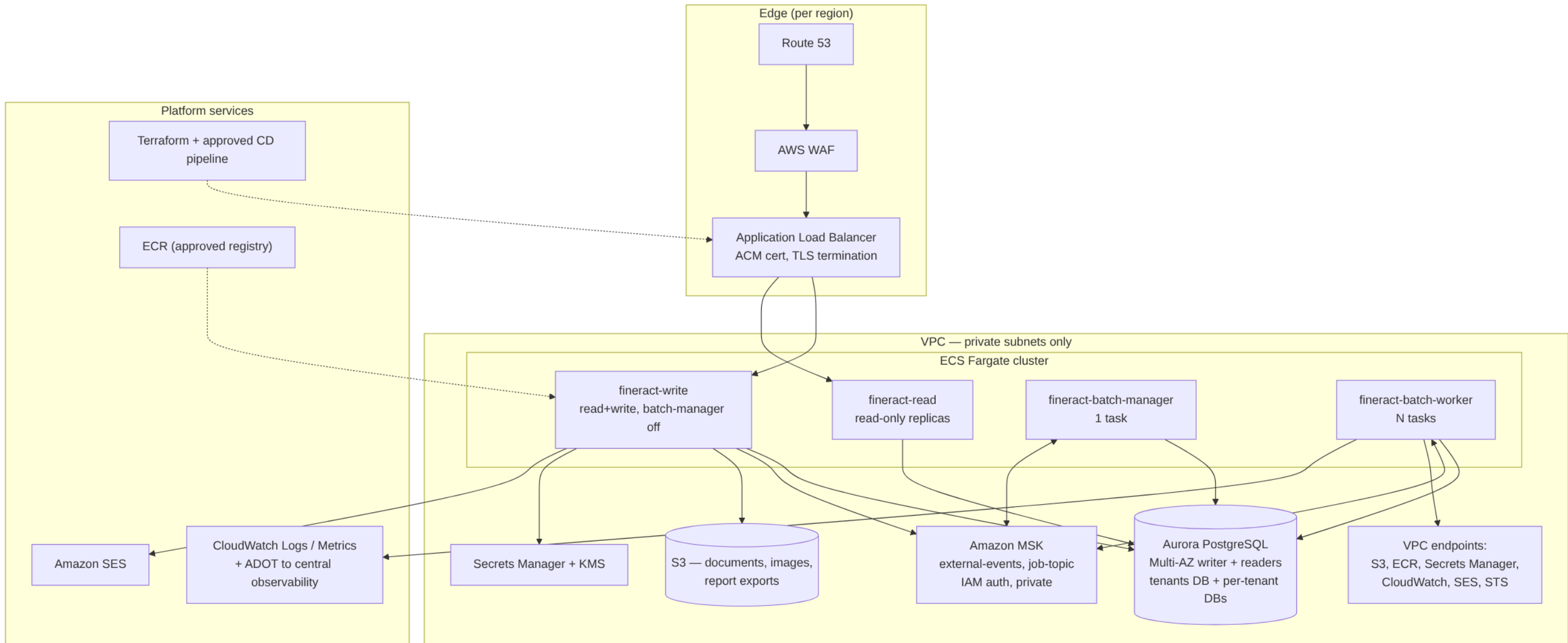
12. What this repository cannot tell us

Listed in full, with owners, in [open-questions.md](#). In summary: which artefact is actually deployed today, on what infrastructure, with which database engine and volumes, under what RTO/RPO, and who operates it.

Target State — Apache Fineract on AWS

Companion to [current-state.md](#). Every component in the current state is mapped to a target AWS service, assessed against the platform guardrails below.

Two inputs were not supplied for this package and are assumed. The approved ("blessed") AWS service list in §1 and the platform guardrails in §2 are **assumed defaults, not the customer's own policy**. Confirming or replacing them is [OQ-P1](#) and [OQ-P2](#) and must be closed before design sign-off. Where the natural choice falls outside the assumed list it is tagged `OFF-LIST?` with an in-list alternative rather than being substituted silently.



1. Assumed approved service list

Assumed, pending confirmation (OQ-P1). Only the services below are used in the target design.

Compute and delivery: ECS on Fargate, ECR, AWS CodePipeline/CodeBuild or the customer's existing pipeline tool, Terraform, AWS Control Tower / Organizations, Systems Manager. Networking and edge: VPC (private subnets, NAT, VPC endpoints), Application Load Balancer, Route 53, ACM, AWS WAF, Transit Gateway/PrivateLink. Data: Aurora PostgreSQL, S3, Amazon MSK, Amazon MQ (ActiveMQ), ElastiCache (Redis). Security: IAM, KMS, Secrets Manager, GuardDuty, Security Hub, CloudTrail, Config. Observability: CloudWatch Logs/Metrics/Alarms, AWS Distro for OpenTelemetry, X-Ray. Messaging out: Amazon SES, Amazon SNS. Resilience: AWS Backup, Route 53 ARC or DNS failover.

2. Platform migration guardrails in force

These are the default guardrail set, assumed because the customer's own guardrails were not supplied (OQ-P2). They are not presented as the customer's policy.

G	Guardrail
G1	Approved-service allowlist — only allow-listed services appear in the target; the allowlist is assumed to be enforced organisation-wide by SCPs.
G2	Containers first — a managed container platform is the preferred compute target; VM lift-and-shift needs explicit justification.
G3	Standard target RDBMS — relational workloads target PostgreSQL; staying on another engine is an exception that must be justified.
G4	Account vending and environment promotion — onboarding via the standard vending process with separate dev, QA and prod accounts; dev runs before QA is granted; changes promote dev → QA → prod.
G5	Everything as code — all target infrastructure in the approved IaC tool; no console-built resources.
G6	Approved delivery toolchain — CI/CD on approved pipeline tooling; moving off legacy pipelines is part of the plan.
G7	Production entry criteria — prod requires the stated resilience posture (multi-region), load balancing, and a demonstrated DR/failover test.
G8	Security baseline — private networking by default, encryption in transit and at rest, least-privilege IAM roles with no long-lived static credentials, secrets in the approved secrets manager.
G9	Approved artifact sources — images and dependencies only from approved registries/repositories.
G10	Tagging and observability standards — mandatory tags (owner, cost centre, environment, data classification) and logs/metrics to the central observability platform.

Assumed environment posture, also pending confirmation (OQ-P3): dev and QA multi-AZ single region, production multi-region active/passive; target RDBMS PostgreSQL; target compute ECS Fargate.

3. Component mapping

Effort is expressed in engineering-sessions of focused work, not calendar time. Risk is H/M/L.

#	Current component (evidence)	Target AWS service	Rationale	Risk	Effort
1	Fineract Spring Boot container, <code>type: LoadBalancer</code> on 8443, single replica, <code>Recreate</code> strategy (<code>kubernetes/fineract-server-deployment.yml:26-50</code>)	ECS Fargate service behind an ALB , rolling deployment, ≥2 tasks across AZs	G2 satisfied without running a cluster control plane; the app is already a stateless container with liveness/readiness endpoints (: 71-86). EKS is the alternative if the organisation standardises on Kubernetes — see OQ-P4	M	2
2	Four runtime modes read / write / batch-manager / batch-worker (<code>application.properties:67-70</code> ; <code>config/docker/env/fineract-manager.env:20-26</code>)	Four ECS services off one image, differing only in env: <code>fineract-write</code> , <code>fineract-read</code> , <code>fineract-batch-manager</code> (1 task, no autoscaling), <code>fineract-batch-worker</code> (scaled on queue depth)	The manager/worker split already exists in the Kafka compose profile (<code>docker-compose-postgresql-kafka.yml:33-63</code>); the manager must stay at one task because jobs are bound to <code>node-id</code> (<code>JobRegisterServiceImpl.java:206-212</code>)	M	2
3	MariaDB 11.4 in-cluster on a <code>hostPath</code> PV (<code>kubernetes/fineractmysql-deployment.yml:26-47,89</code>)	Aurora PostgreSQL , Multi-AZ writer + reader endpoint, automated backups, KMS-encrypted	G3. No stored procedures exist (0 matches) and PostgreSQL is already a first-class engine with its own CI lane (<code>.github/workflows/build-postgresql.yml</code>), so the engine change is a data/ops workstream, not a code rewrite	H	8
4	Per-tenant databases + <code>fineract_tenants</code> registry (<code>application.properties:44-53</code>)	One Aurora cluster per environment, one database per tenant inside it; tenant registry unchanged	Preserves the application's tenancy model with no code change. Tenant-per-cluster is the alternative if isolation requirements demand it (OQ-D3)	M	2
5	Read-only replica settings already present but unused (<code>application.properties:56-62</code>)	Point <code>fineract-read</code> tasks at the Aurora reader endpoint	Existing configuration surface; removes reporting load from the writer	L	1
6	Liquibase runs at application start, 318 changelogs (<code>application.properties:433-434</code>)	Liquibase as a one-shot ECS task gated in the pipeline; <code>FINERACT_LIQUIBASE_ENABLED=false</code> on service tasks, as the worker profile already does (<code>config/docker/env/fineract-worker.env:24</code>)	Prevents N tasks racing on the same schema; makes migrations a reviewable pipeline stage	M	2
7	Document/image content on container-local disk (<code>application.properties:186-187</code> ; <code>/tmp</code> at <code>config/docker/env/fineract-common.env:57</code>)	S3 with SSE-KMS, versioning, <code>fineract.content.s3.enabled=true</code> , credentials via task role (<code>application.properties:376</code>)	Removes the only stateful local disk (C10); the S3 path already exists in the code, so this is configuration plus data copy	M	2
8	Report export to S3, disabled (<code>application.properties:202-203</code>)	Same S3 bucket, separate prefix and lifecycle policy	Already supported	L	1

#	Current component (evidence)	Target AWS service	Rationale	Risk	Effort
9	External events + remote job dispatch over Kafka, MSK profile present (config/docker/env/kafka-client-msk.env:23-33)	Amazon MSK in private subnets, SASL_SSL + AWS_MSK_IAM auth, IAM-authenticated topics	The IAM auth wiring already exists; fix C2 (the : instead of = on line 33) and drop the public bootstrap endpoints (C6)	M	3
10	JMS/ActiveMQ alternative producer (application.properties:129-137)	Amazon MQ (ActiveMQ) — only if the organisation prefers JMS over Kafka	Both paths are supported by the app; pick one (OQ-D4)	L	1
11	Quartz with in-memory job store, jobs pinned to node-id (JobRegisterServiceImpl.java:319-331)	Keep Quartz, single batch-manager task, plus a JDBC-clustered job store as follow-on work	In-memory Quartz plus >1 manager task double-fires jobs; in-memory Quartz plus rolling deploys loses in-flight COB runs (C7). This is the highest-risk behavioural item in the migration	H	5
12	SMTP e-mail (GmailBackedPlatformEmailService.java, ReportMailingJobEmailServiceImpl.java)	Amazon SES SMTP interface, credentials in Secrets Manager	Drop-in for host/port/credentials, which are already read from the database at runtime (ExternalServicesPropertiesReadPlatformServiceImpl.java:82-94)	L	1
13	SMS gateway + Twilio hook (hooks/processor/TwilioHookProcessor.java, ...:136-142)	Unchanged third-party endpoints, egress via NAT gateway ; SNS only if the customer wants to replace the provider	Third-party contracts are out of scope for the platform migration	L	1
14	ElasticSearch hook (hooks/processor/ElasticSearchHookProcessor.java)	OFF-LIST? — OpenSearch Service is the natural AWS target but is not on the assumed allowlist . In-list alternative: keep the hook pointing at the existing external cluster over PrivateLink, or disable it	Flagged rather than substituted, per G1	M	1
15	Web hooks / outbound HTTP with fineract.insecure-http-client=true (application.properties:221)	Same egress path, but set the flag to false and use ACM/private CAs	G8: TLS verification must be on outside a laptop	M	1
16	Secrets: env files with a committed DB password (config/docker/env/fineract-common.env:31), script-generated k8s Secret (kubernetes/kubectL-startup.sh:24), external-service credentials in the tenant DB	Secrets Manager with rotation for DB and SES credentials, injected into ECS task definitions; KMS CMKs; no static AWS keys anywhere	G8. External-service credentials stored inside tenant tables stay where they are but the columns must be KMS/ Aurora-encrypted at rest (OQ-S2)	M	3
17	Self-signed keystore, default keystore password, TLS terminated in the JVM (application.properties:386-391)	TLS terminated at the ALB with an ACM certificate; in-VPC hop to the task over HTTP or a private-CA cert	Removes the bundled keystore and the proxy_ssl_verify off workaround (C4)	L	1
18	Basic auth default, OAuth2 present but off, 2FA off, CORS * with credentials (application.properties:24-35)	Keep Basic auth for machine clients initially; enable OAuth2 against the corporate IdP; restrict CORS to known origins; enable HSTS	Security posture decision, not a platform constraint (OQ-S1)	M	3
19	Docker Hub apache/fineract, mutable :latest in the manifest (.github/workflows/publish-dockerhub.yml:47; kubernetes/fineract-server-deployment.yml:63)	ECR with immutable tags and scan-on-push; deploy by digest	G9 and C1: what CI tested must be what runs	L	2
20	No deployment pipeline at all (no kubectL/helm/argo step in any of the 19 workflows)	Approved CD tool promoting dev → QA → prod, deploying ECS task definitions by image digest, with the Liquibase task as a gated stage	G4 and G6. This is net-new, not a migration	M	5
21	No IaC in the repository — three YAML manifests applied by kubernetes/kubectL-startup.sh:25-45	Terraform modules: network, Aurora, ECS services, MSK, S3, IAM, observability; state in S3 + DynamoDB lock	G5	M	8
22	Prometheus endpoint and CloudWatch export, both off (application.properties:347,358,362-367)	CloudWatch metrics + logs, ADOT sidecar exporting OTLP traces (:354-356) to the central platform; actuator exposure unchanged	G10; the export paths already exist behind flags	L	2
23	No environment separation of any kind in the repo	Separate dev / QA / prod accounts via account vending, one Terraform workspace per environment	G4	M	3
24	Single-region, single-replica, Recreate (full outage per release)	Multi-AZ in every environment; multi-region active/passive for prod with Aurora Global Database and Route 53 failover	G7. Aurora Global Database is the assumption behind the RPO estimate — confirm target RTO/RPO (OQ-O1)	H	8
25	Mifos web-app UI openmf/web-app:master behind nginx with proxy_ssl_verify off (kubernetes/fineract-mifoscommunity-deployment.yml:48,102)	Out of scope for this repository. If in scope: S3 + CloudFront static hosting with the API behind the same ALB (OQ-A2)	L	—	
26	Compose exposes a JDWP debug agent and runs test,diagnostics profiles (docker-compose.yml:32; config/docker/env/fineract-common.env:58,60)	Not carried forward; compose stays a local-development artefact	G8: no debug agent and no test profile in any AWS environment	L	—

4. Guardrail compliance

G	How the target design satisfies it	Exception / open item
G1 Allowlist	Every row in §3 targets a service in the §1 list	Row 14 (ElasticSearch hook) is tagged OFF-LIST? with two in-list alternatives. The whole list is assumed — OQ-P1
G2 Containers first	ECS Fargate for all four runtime modes (rows 1-2); no EC2, no VM lift-and-shift	ECS vs EKS is OQ-P4
G3 Standard RDBMS	Aurora PostgreSQL (row 3); the application already ships the PostgreSQL driver (fineract-provider/build.gradle:302) and tests against it in CI	None — but the MariaDB → PostgreSQL data conversion is workstream WS3, not a config flag
G4 Account vending / promotion	Separate dev, QA, prod accounts (row 23); pipeline promotes dev → QA → prod (row 20); dev stands up first in WS1	Account vending lead time is external — OQ-P5
G5 Everything as code	Terraform modules for all target infrastructure (row 21); the current kubectl apply script is retired	None
G6 Approved toolchain	CD pipeline is net-new (row 20); GitHub Actions CI is retained for build/test and publishes to ECR (row 19)	Which CD tool is approved — OQ-DL1
G7 Production entry criteria	Multi-region active/passive, ALB in front of every service, DR failover test as a WS8 entry criterion (row 24)	Target RTO/RPO unconfirmed — OQ-O1
G8 Security baseline	Private subnets with VPC endpoints; ALB/ACM TLS in transit (row 17); KMS at rest on Aurora, S3, MSK; task roles instead of static keys (rows 7, 16); Secrets Manager for DB and SES credentials (row 16); fineract.insecure-http-client=false (row 15)	Committed local-dev DB password (config/docker/env/fineract-common.env:31) and the public MSK endpoints (C6) must be dealt with in WS0 — OQ-S3
G9 Approved artifact sources	ECR with immutable tags, scan-on-push, deploy by digest (row 19); the Jib base image azul/zulu-openjdk-alpine:21 must be mirrored into the approved registry, and allowInsecureRegistries = true (fineract-provider/build.gradle:298) must not be used against ECR	Which registry mirrors public base images — OQ-DL2
G10 Tagging and observability	Mandatory tag set applied by Terraform default tags (row 21); CloudWatch + ADOT export (row 22); correlation-ID header already available (application.properties:76-77)	Exact mandatory tag keys and the central platform's ingest endpoint — OQ-O2

Open Questions

Everything the repository cannot settle. Each question is addressed to the role that owns the answer and carries an ID referenced by [target-state.md](#) and [migration-plan.md](#). Questions marked **blocking** must be closed before design sign-off.

Programme

ID	Question	Owner	Blocking
OQ-P1	The approved ("blessed") AWS service list was not supplied, so §1 of the target-state document is an assumed list. Is it correct, and what is the real allowlist enforced by SCP?	Platform Engineering	Yes
OQ-P2	The platform migration guardrails were not supplied, so the default set in §2 of the target-state document is assumed. Which of these are actually in force, and what have we missed?	Platform Engineering	Yes
OQ-P3	Confirm the environment posture we assumed: dev and QA multi-AZ single region, production multi-region active/passive. Is active/active required, and which regions?	Platform Engineering	Yes
OQ-P4	We selected ECS Fargate over EKS for guardrail G2. Does the organisation mandate Kubernetes as the managed container platform? If so the compute rows change but nothing else does.	Platform Engineering	Yes
OQ-P5	What is the lead time and approval path for vending the dev, QA and prod accounts? This sets the start date of WS1 and everything after it.	Platform Engineering	Yes
OQ-P6	Is C0G-GTM/fineract-Core-Banking the artefact actually deployed today, or is production running a fork, a vendor build, or a different Fineract version? Nothing in this repository can answer that.	Application Owner	Yes
OQ-P7	Is the Mifos web-app UI (kubernetes/fineract-mifoscommunity-deployment.yml:102) in scope for this migration, or is the customer's own front end used?	Application Owner	Yes
OQ-P8	Are custom modules under custom/ (e.g. custom/acme/loan, custom/acme/note) real customer extensions that must migrate, or sample scaffolding?	Application Owner	Yes

Database

ID	Question	Owner	Blocking
OQ-D1	Which engine is production on today — MariaDB or PostgreSQL — and at what version? The repository supports both (README.md:33) and defaults to MariaDB (application.properties:405-406). If it is already PostgreSQL, workstream WS3 collapses to a homogeneous data move.	DBA	Yes
OQ-D2	Production data volumes: total size, largest tables, row counts on m_loan_transaction / journal entries, and daily growth. This sets the conversion window and whether DMS CDC is needed.	DBA	Yes
OQ-D3	How many tenants exist, and does any tenant require database- or cluster-level isolation beyond database-per-tenant inside one Aurora cluster?	DBA / Application Owner	Yes
OQ-D4	Are there any objects in the production schemas that are not managed by the 318 Liquibase changelogs — hand-created views, triggers, scheduled events, grants, or reporting-only tables? The repository has zero stored procedures, but reports are user-defined and stored in the database (ReadReportingServiceImpl.java).	DBA	Yes
OQ-D5	The m_report / stretchy-reporting tables hold user-authored SQL executed at runtime. Has anyone inventoried that SQL for MariaDB-specific dialect (backticks, IFNULL, LIMIT x,y, DATE_FORMAT)? It is data, so it will not appear in any code diff.	DBA / Application Owner	Yes
OQ-D6	Is there a read-only replica in use today? The configuration surface exists but is empty (application.properties:56-62).	DBA	No
OQ-D7	What is the current backup, retention and point-in-time-recovery arrangement, and what must Aurora match?	DBA	Yes

Platform

ID	Question	Owner	Blocking
OQ-A1	What actually runs the workload today — the committed Kubernetes manifests, a Helm chart held elsewhere, or VMs running the WAR on Tomcat (fineract-war/build.gradle:21)? The manifests use a hostPath volume (C3), which is a single-node construct, so they are unlikely to be the production truth.	Platform Engineering / Application Owner	Yes

ID	Question	Owner	Blocking
OQ-A2	Real hostnames, DNS zones and certificate authority for the API and UI: what names must survive cutover, and who controls those DNS records?	Platform Engineering	Yes
OQ-A3	Which clients call the API, from which networks, and can they be moved behind a private ALB, or is public internet exposure required (in which case WAF rules and rate limits need defining)?	Application Owner / Security	Yes
OQ-A4	Is external eventing (Kafka/MSK) actually used in production? It is disabled by default (<code>application.properties:124</code>) but an MSK profile is committed (<code>config/docker/env/kafka-client-msk.env</code>). If unused, MSK drops out of the target entirely.	Application Owner	Yes
OQ-A5	Does the <code>democluster1</code> MSK cluster in <code>eu-central-1</code> referenced at <code>config/docker/env/kafka-client-msk.env:23</code> exist, who owns it, and is it in scope?	Platform Engineering	Yes
OQ-A6	How large is the document/image store today (currently container-local disk, C10), and is any of it business-critical data that must be preserved on migration to S3?	Application Owner	Yes
OQ-A7	Peak and average API throughput, concurrent users, and the COB batch window — needed to size ECS task counts and the Aurora writer.	Application Owner	Yes

Delivery

ID	Question	Owner	Blocking
OQ-DL1	Which CD tool is approved? There is no deployment automation of any kind in this repository, so this is net-new work, and the choice shapes workstream WS6.	Release Manager	Yes
OQ-DL2	Which registry must the Jib base image <code>azul/zulu-openjdk-alpine:21</code> (<code>fineract-provider/build.gradle:266</code>) and all Gradle dependencies come from, per guardrail G9? Is there an internal mirror/proxy?	Release Manager / Platform Engineering	Yes
OQ-DL3	How is a release approved today, and who authorises a production deployment? The current path is a manual <code>kubectl apply</code> (<code>kubernetes/kubectl-startup.sh:25-45</code>).	Release Manager	Yes
OQ-DL4	Should GitHub Actions remain the CI system, publishing to ECR instead of Docker Hub (<code>.github/workflows/publish-dockerhub.yml:43-48</code>), or must CI also move?	Release Manager	Yes
OQ-DL5	What is the acceptable release outage? Today every release is a full outage because the deployment strategy is <code>Recreate</code> (<code>kubernetes/fineract-server-deployment.yml:49-50</code>); ECS rolling deployments remove that, but only if the Liquibase changes are backward-compatible.	Release Manager / Application Owner	Yes

Security

ID	Question	Owner	Blocking
OQ-S1	Authentication target: keep HTTP Basic (<code>application.properties:24</code>), or enable the OAuth2 support against the corporate IdP (<code>:25,37-42</code>)? Is 2FA (<code>:26</code>) required for any user population?	Security / Application Owner	Yes
OQ-S2	SMTP, SMS and S3 credentials are stored in tenant database tables and read at runtime (<code>ExternalServicesPropertiesReadPlatformServiceImpl.java:54-94</code>). Is that acceptable under the secrets guardrail (G8) given Aurora KMS encryption at rest, or must they move to Secrets Manager — which would require an application change?	Security	Yes
OQ-S3	The default CORS configuration is <code>*</code> with <code>allow-credentials=true</code> (<code>application.properties:31,35</code>) and the actuator CORS origin is <code>*</code> (<code>:341</code>). What origin list should the deployed configuration use?	Security	Yes
OQ-S4	<code>fineract.insecure-http-client</code> defaults to <code>true</code> (<code>application.properties:221</code>), disabling outbound TLS verification. Confirm it is set to <code>false</code> in all AWS environments, and identify any integration endpoint with a private-CA certificate that then needs a trust store.	Security	Yes
OQ-S5	Data classification of the tenant data (PII, financial records) — this drives the mandatory tag set (G10), KMS key policy, and whether cross-region replication for the DR posture is permitted.	Security / Data Governance	Yes
OQ-S6	Is a WAF ruleset mandated in front of internet-facing services, and does the customer have a standard rule group?	Security	Yes

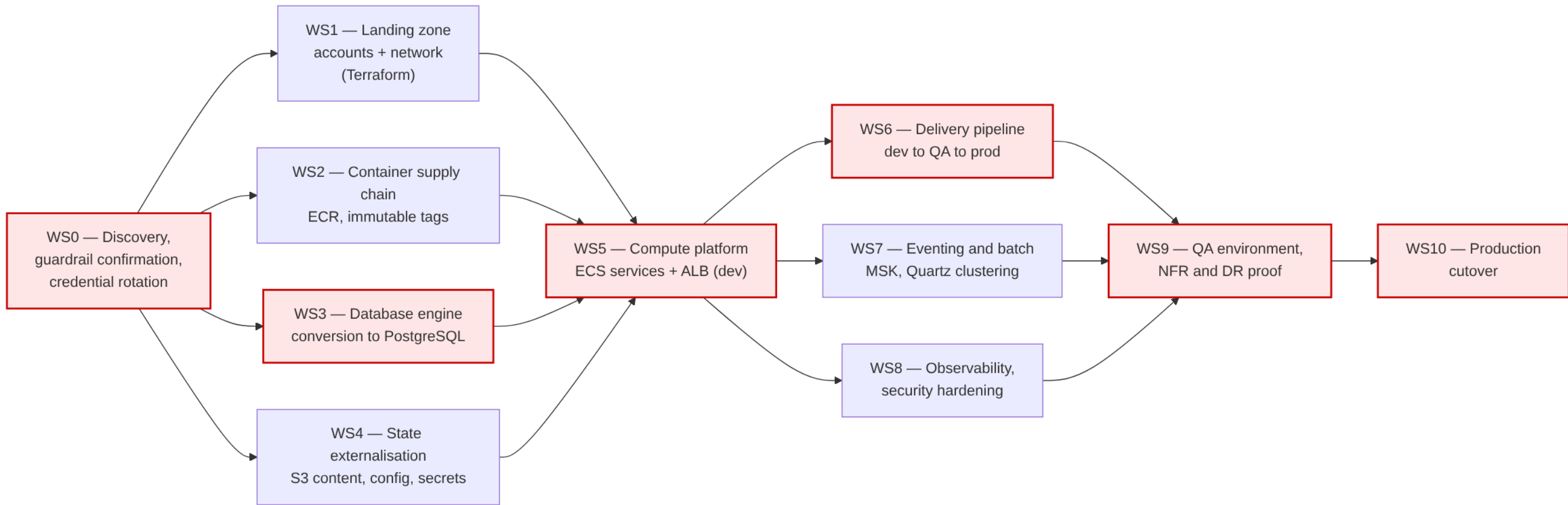
ID	Question	Owner	Blocking
OQ-S7	Who rotates the database credentials today? The Kubernetes secret is generated once by a shell script with no rotation path (<code>kubernetes/kubectℓ-startup.sh:24</code>), and a working DB password is committed to the local-development env file (<code>config/docker/env/fineract-common.env:31</code>).	Security	Yes

Operations

ID	Question	Owner	Blocking
OQ-O1	Target RTO and RPO for the platform. Nothing in the repository implies either, and the multi-region prod posture (G7) is only meaningful against a number.	Application Owner / Business	Yes
OQ-O2	The mandatory tag keys (owner, cost centre, environment, data classification) and the ingest endpoint of the central observability platform.	Platform Engineering	Yes
OQ-O3	Which alerts and dashboards exist today, and what constitutes a page? The application exposes <code>health</code> , <code>info</code> and <code>prometheus</code> only (<code>application.properties:347</code>).	Operations	Yes
OQ-O4	The COB batch window and its business deadline. The COB job is partitioned and node-bound (<code>application.properties:88-95</code> ; <code>JobRegisterServiceImpl.java:206-212</code>), so a missed window is a business incident, and the Quartz in-memory job store (C7) means an in-flight run is lost on task replacement.	Operations / Application Owner	Yes
OQ-O5	Who operates the platform after cutover, and does that team already run ECS and Aurora, or is enablement part of the programme?	Operations	Yes
OQ-O6	Is there a compliance or audit obligation on log retention and the immutable command audit trail that constrains CloudWatch retention settings?	Operations / Compliance	Yes

Migration Plan

Ordered workstreams from discovery to production cutover. Each workstream is independently reviewable, states its entry criteria and dependencies, and references the open questions ([open-questions.md](#)) that must be closed before it can start. Effort is in engineering-sessions of focused work, not calendar time; account vending, security review and customer sign-off are external waits and are called out separately.



Critical path (highlighted above): WS0 → WS3 → WS5 → WS6 → WS9 → WS10. The engine conversion (WS3) is the long pole: it is the only workstream whose duration is driven by production data volume rather than by engineering effort, and every functional test in WS9 depends on it. WS1, WS2, WS4, WS7 and WS8 can run alongside it. If OQ-D1 comes back "production is already PostgreSQL", WS3 drops from ~8 sessions to ~2 and the critical path shifts to WS5 → WS6 → WS9.

WS0 — Discovery, guardrail confirmation and credential remediation

Entry criteria: repository access (done); a named owner for each role in the open-questions document. **Dependencies:** none. **Closes:** OQ-P1, OQ-P2, OQ-P3, OQ-P4, OQ-P6, OQ-A1, OQ-A4, OQ-D1, OQ-D2, OQ-S5, OQ-O1.

1. Confirm or replace the assumed approved-service list and the assumed guardrail set. Until this is done every service choice in the target-state document is provisional.
2. Establish what actually runs in production (OQ-A1, OQ-P6). The committed Kubernetes manifests use a `hostPath` volume and a single-replica `Recreate` deployment, which is not a production shape; treat them as a development sample until proven otherwise.
3. **Credential rotation and revocation.** A working local-development database password is committed at `config/docker/env/fineract-common.env:31`, a default tenant database password at `:51`, and placeholder AWS credentials at `config/docker/aws/etc/credentials`. Confirm none of these values is reused in any real environment; if any is, rotate it and revoke the old value before anything else in this plan proceeds. Also confirm the self-signed keystore password (`application.properties:391`) is not in use outside local development. Remediation of the committed values in the repository is separate follow-up work — this package is docs-only.
4. Inventory the user-authored report SQL held in the database (OQ-D5) — it is invisible to code review and is the largest single unknown in WS3.

Effort: 3 sessions of analysis, plus external time waiting on answers.

WS1 — Landing zone: accounts, network, IaC foundation

Entry criteria: WS0 complete; guardrails confirmed (OQ-P2); account-vending path known (OQ-P5). **Dependencies:** WS0. **Closes:** OQ-P5, OQ-A2, OQ-A3, OQ-O2.

Vend dev, QA and prod accounts (G4); dev first — QA is not requested until dev is running. Terraform repository and remote state; VPC with private subnets, NAT, and VPC endpoints for S3, ECR, Secrets Manager, CloudWatch, SES and STS (G8); Route 53 zones; ACM certificates; mandatory default tags (G10); GuardDuty, Config, CloudTrail and Security Hub baselines.

Effort: 8 sessions. External: account vending lead time.

WS2 — Container supply chain

Entry criteria: WS0 complete; approved registry identified (OQ-DL2). **Dependencies:** WS0. **Closes:** OQ-DL2, OQ-DL4.

Create ECR repositories with tag immutability and scan-on-push; mirror the Jib base image `azul/zulu-openjdk-alpine:21` (`fineract-provider/build.gradle:266`) into the approved registry; retarget the existing publish workflow from `docker.io/apache/fineract` (`.github/workflows/publish-dockerhub.yml:47`) to ECR with OIDC-federated credentials instead of the `DOCKERHUB_USER/DOCKERHUB_TOKEN` secrets; deploy by digest so the mutable `:latest` reference in `kubernetes/fineract-server-deployment.yml:63` (finding C1) cannot recur.

Effort: 3 sessions.

WS3 — Database engine conversion to Aurora PostgreSQL

Entry criteria: WS0 complete; production engine, version and data volume known (OQ-D1, OQ-D2); non-Liquibase schema objects inventoried (OQ-D4); report SQL inventoried (OQ-D5). **Dependencies:** WS0. **Closes:** OQ-D3, OQ-D4, OQ-D5, OQ-D7.

This is a workstream, not a table row. In its favour: there are zero stored procedures and zero `CallableStatement` uses in the codebase, the PostgreSQL driver already ships in the image (`fineract-provider/build.gradle:302`), and CI already runs the full suite against PostgreSQL (`.github/workflows/build-postgresql.yml`). Against it: 204 non-test files use `JdbcTemplate`, and the user-authored report SQL stored in the database is not covered by any test.

1. Stand up Aurora PostgreSQL in dev; run Liquibase from scratch and diff the resulting schema against a MariaDB-built schema.
2. Convert and re-test the stored report SQL (OQ-D5).
3. Full-volume trial conversion with DMS (or `pg_loader/dump-restore` if the outage budget allows), measured end-to-end, then a CDC-based rehearsal to size the cutover window.
4. Row-count and checksum reconciliation; performance comparison of the heaviest queries.
5. Decide database-per-tenant-in-one-cluster versus cluster-per-tenant (OQ-D3).

Effort: 8 sessions, plus rehearsal runs whose duration is set by data volume.

WS4 — State externalisation

Entry criteria: WS0 complete; content-store size and criticality known (OQ-A6); secrets policy decided (OQ-S2). **Dependencies:** WS0. **Closes:** OQ-A6, OQ-S2, OQ-S7.

Enable `fineract.content.s3.enabled` (`application.properties:188`) with a KMS-encrypted, versioned bucket and an ECS task role rather than static keys; copy existing document/image content off local disk (finding C10, `application.properties:186-187` and the `/tmp` override at `config/docker/env/fineract-common.env:57`); move the database and SES credentials into Secrets Manager with rotation; decide whether the external-service credentials held in tenant tables (`ExternalServicesPropertiesReadPlatformServiceImpl.java:54-94`) stay there under Aurora encryption or require an application change (OQ-S2 — an application change is out of scope for this programme and would need its own ticket).

Effort: 4 sessions.

WS5 — Compute platform in dev

Entry criteria: WS1, WS2, WS3 and WS4 complete for the dev environment; ECS-versus-EKS decided (OQ-P4); throughput and batch-window figures available for sizing (OQ-A7). **Dependencies:** WS1, WS2, WS3, WS4.

Terraform the ECS Fargate cluster and the four services (`fineract-write`, `fineract-read`, `fineract-batch-manager` at exactly one task, `fineract-batch-worker`) from one image, differing only in environment variables as the existing compose profiles already do (`config/docker/env/fineract-manager.env`, `fineract-worker.env`). ALB with an ACM certificate terminating TLS, replacing the in-JVM keystore (`application.properties:386-391`) and the raw `type: LoadBalancer` service (`kubernetes/fineract-server-deployment.yml:26-33`). Health checks onto the existing `/actuator/health` endpoint (`:71-86`). Liquibase disabled on service tasks and run as a one-shot task instead (`application.properties:433`). Right-size CPU and memory against the README's 16 GB / 8-core guidance rather than the 1 vCPU / 2 GiB in the manifest (finding C8).

Effort: 8 sessions.

WS6 — Delivery pipeline

Entry criteria: WS5 running in dev; approved CD tool known (OQ-DL1); approval path known (OQ-DL3); acceptable release outage agreed (OQ-DL5). **Dependencies:** WS5. **Closes:** OQ-DL1, OQ-DL3, OQ-DL5.

Net-new: there is no deployment automation anywhere in this repository — none of the 19 GitHub Actions workflows deploys anything, and the only deployment path committed is a manual shell script (`kubernetes/kubect1-startup.sh:25-45`). Build a promotion pipeline `dev → QA → prod` (G4, G6) that deploys ECS task definitions by digest, runs the Liquibase task as a gated stage, and requires approval at the QA and prod boundaries. Rolling deployments replace the `Recreate` full-outage strategy (`kubernetes/fineract-server-deployment.yml:49-50`), which requires Liquibase changes to be backward-compatible — the repository already runs a Liquibase backward-compatibility check in CI (`.github/workflows/`), which should become a pipeline gate.

Effort: 5 sessions.

WS7 — Eventing and batch correctness

Entry criteria: WS5 running in dev; external eventing confirmed in use (OQ-A4); COB window and deadline known (OQ-O4). **Dependencies:** WS5. **Closes:** OQ-A4, OQ-A5, OQ-O4.

Provision MSK in private subnets with `SASL_SSL` and `AWS_MSK_IAM` auth, replacing the public bootstrap endpoints in `config/docker/env/kafka-client-msk.env:23` (finding C6) and correcting the malformed `:` assignment at `:33` (finding C2) in whatever configuration is actually deployed. Address the Quartz job store (finding C7): the scheduler is created with only a thread count set (`JobRegisterServiceImpl.java:319-331`), so it uses the in-memory store — jobs are lost on task replacement and would double-fire if the batch-manager service ever ran more than one task. Either pin the manager to one task and accept restart loss, or move Quartz to a JDBC-clustered job store. The decision must be recorded before WS9, because the DR proof depends on it.

Effort: 5 sessions.

WS8 — Observability and security hardening

Entry criteria: WS5 running in dev; tag keys and observability endpoint known (OQ-O2); auth target decided (OQ-S1); CORS origins agreed (OQ-S3). **Dependencies:** WS5. **Closes:** OQ-S1, OQ-S3, OQ-S4, OQ-S6, OQ-O2, OQ-O3, OQ-O6.

CloudWatch logs and metrics plus an ADOT sidecar exporting the OTLP traces the application already supports (`application.properties:354-356`); dashboards and alarms for the COB job, API latency and Aurora health (OQ-O3). Set `fineract.insecure-http-client=false` (`application.properties:221`, OQ-S4); restrict the CORS origin patterns from `*` (`:31,35`) and the actuator CORS origin (`:341`); decide Basic auth versus OAuth2 and 2FA (OQ-S1); WAF ruleset if the API is internet-facing (OQ-A3, OQ-S6); confirm no `test/diagnostics` Spring profile and no JDWP agent reaches any AWS environment (`config/docker/env/fineract-common.env:58,60`; `docker-compose.yml:32` — findings C5 and C9).

Effort: 5 sessions.

WS9 — QA environment, NFR validation and DR proof

Entry criteria: dev environment stable and promoted through the WS6 pipeline; QA account vended (G4 requires dev running before QA is granted); WS7 and WS8 complete; RTO/RPO targets stated (OQ-O1). **Dependencies:** WS6, WS7, WS8.

Terraform-apply the same modules into QA; run the full functional suite against Aurora PostgreSQL; performance-test to the OQ-A7 figures; run a full-volume COB batch inside the OQ-O4 window; run a restore-from-backup test and a documented multi-AZ failover; produce the evidence pack that G7 requires. Sign-off from Application Owner, Security and Operations.

Effort: 8 sessions.

WS10 — Production cutover (final workstream)

Entry criteria — all must be met, no exceptions granted informally:

Correctness and security blockers from the current-state analysis: 1. Credential remediation from WS0 complete: every value found committed in the repository is confirmed unused in production or rotated and revoked (config/docker/env/fineract-common.env:31,51; config/docker/aws/etc/credentials). 2. Immutable image references only: production deploys by ECR digest, no :latest (finding C1). 3. Outbound TLS verification enabled (fineract.insecure-http-client=false) and no proxy_ssl_verify off equivalent anywhere in the target (findings C4, C9). 4. No debug agent, no test/diagnostics profile, and no default keystore or default tenant credentials in the production configuration (findings C5, C9). 5. The Quartz job-store decision from WS7 implemented and evidenced: exactly one batch-manager task, or a clustered JDBC job store (finding C7). 6. No stateful local disk: all content served from S3 (finding C10). 7. CORS restricted to an agreed origin list, and the authentication decision from OQ-S1 implemented.

Production entry criteria from guardrail G7: 8. The agreed resilience posture is deployed — multi-AZ in-region, and the multi-region arrangement confirmed in OQ-P3 with Aurora Global Database sized to the OQ-O1 RPO. 9. Load balancing in place: ALB in front of every internet- or client-facing service, ≥2 tasks per service across AZs, rolling deployments proven. 10. A DR/failover test has been executed **in QA** and its evidence accepted — regional failover, database promotion, and measured RTO/RPO against the OQ-O1 targets.

Programme criteria: 11. Every question marked **blocking** in [open-questions.md](#) is closed. 12. WS9 sign-off recorded from Application Owner, Security and Operations. 13. Prod account vended and promoted through the WS6 pipeline with no manual steps.

Dependencies: WS9 (and transitively every other workstream).

Cutover execution: freeze writes; final DMS CDC catch-up and reconciliation; run the Liquibase task; scale up ECS services; smoke-test authenticated endpoints and one COB run; switch Route 53; hold the legacy environment in a read-only, restorable state for an agreed rollback window before decommissioning.

Effort: 5 sessions, plus the rehearsed cutover window itself.